

Fig 1A. First vuln updated

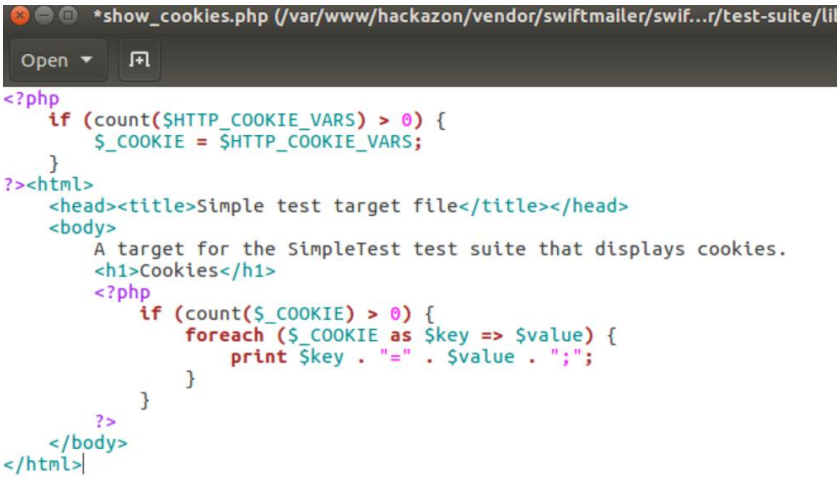


Fig 2A. First vuln

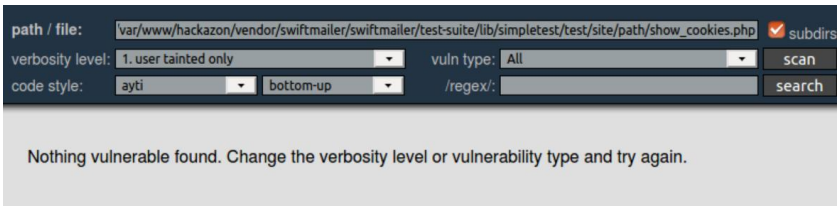


Fig 3A. First vuln fixed

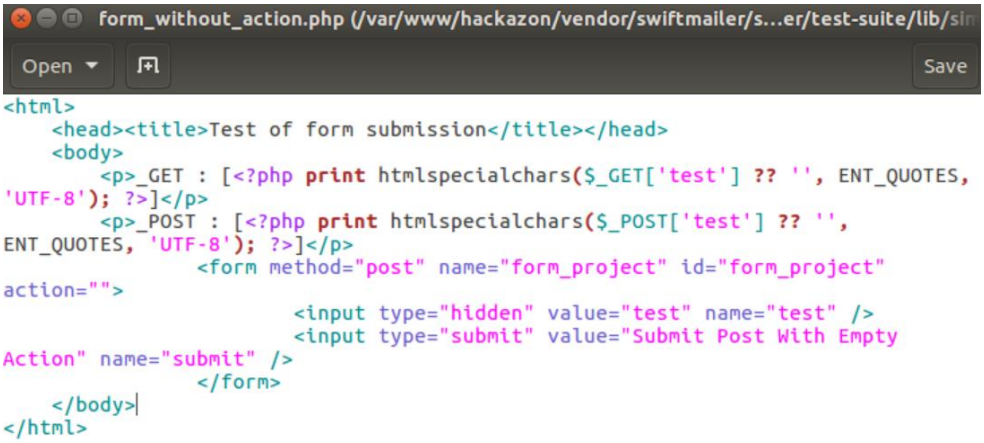


Fig 1B. Second vuln updated

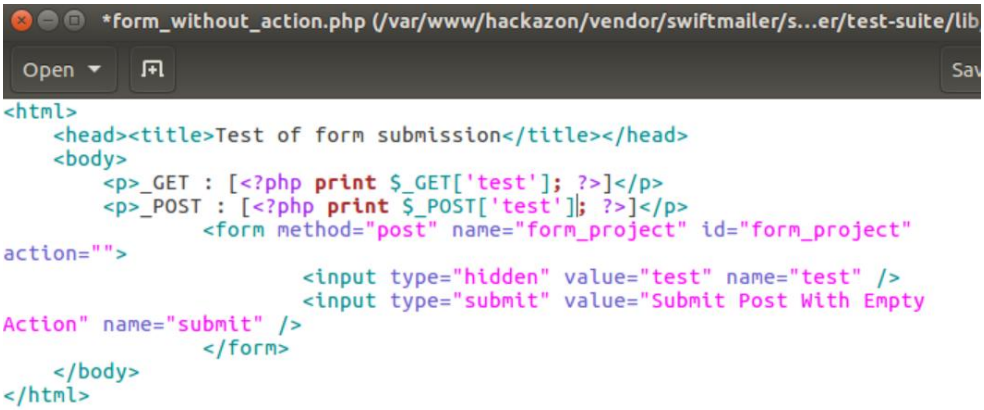


Fig 2B. Second vuln

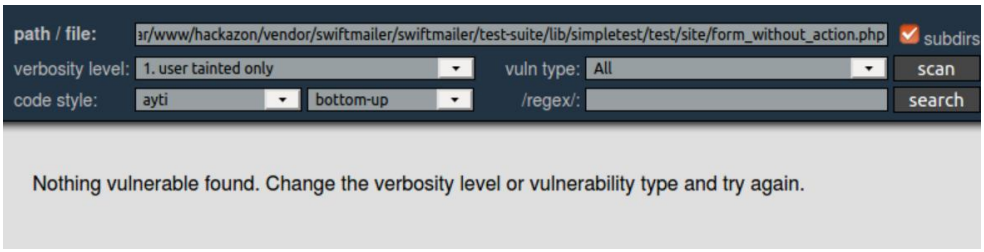


Fig 3B. Second vuln fixed

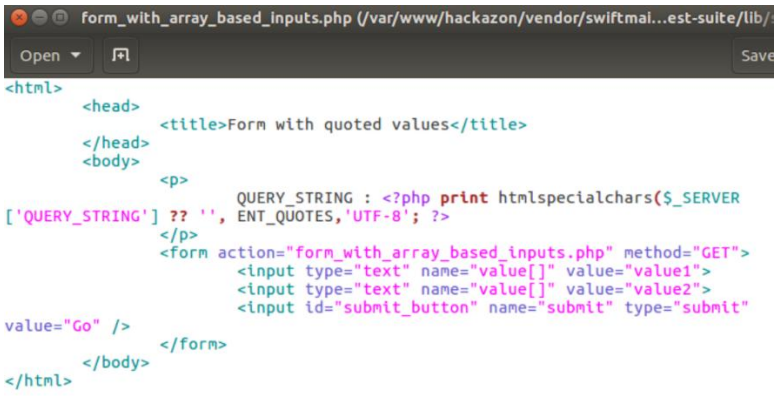


Fig 1C. Third vuln updated

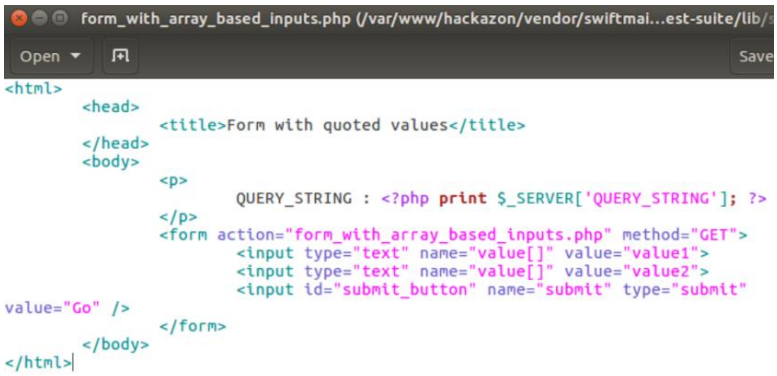


Fig 2C. Third vuln



Fig 3C. Third vuln fixed

All three of the vulnerabilities are fixed by implementing a function called *htmlspecialchars*. This function converts certain special characters into html entities:

& (ampersand) becomes &

" (double quote) becomes "

' (single quote) becomes '

< (less than) becomes <

> (greater than) becomes &gt.

These conversions are very important. This is one of the most simple and effective ways to fix XSS vulnerabilities. By converting those specific characters, we prevent certain html scripts from being run by a web browser. This prevents most XSS attacks as most of those attacks use html scripts. Because at its core an XSS attack is a malicious html script that gets sent to another user's browser, usually through an infected link, and the browser runs it not knowing it isn't from the website. The malicious script can access any cookies, session tokens, or other sensitive information retained by the browser and used with that site. If you want to prevent XSS attacks you must make sure that all variables in a webpage, go through validation. These vulnerabilities show the threat to personal information that exists in the world today

Sources

Cross Site Scripting (XSS) | OWASP Foundation. (n.d.-c). https://owasp.org/www-community/attacks/xss/

PHP: htmlspecialchars - Manual. (n.d.). https://www.php.net/manual/en/function.htmlspecialchars.php